

Security Policy

If you believe you have found a security vulnerability in PHPUnit, please report it to us through coordinated disclosure.

Please do not report security vulnerabilities through public GitHub issues, discussions, or pull requests.

Instead, please email `sebastian@phpunit.de`.

Please include as much of the information listed below as you can to help us better understand and resolve the issue:

- The type of issue
- Full paths of source file(s) related to the manifestation of the issue
- The location of the affected source code (tag/branch/commit or direct URL)
- Any special configuration required to reproduce the issue
- Step-by-step instructions to reproduce the issue
- Proof-of-concept or exploit code (if possible)
- Impact of the issue, including how an attacker might exploit the issue

This information will help us triage your report more quickly.

Web Context

PHPUnit is a framework for writing as well as a command-line tool for running tests. Writing and running tests is a development-time activity. There is no reason why PHPUnit should be installed on a webserver and/or in a production environment.

If you upload PHPUnit to a webserver then your deployment process is broken. On a more general note, if your vendor directory is publicly accessible on your webserver then your deployment process is also broken.

Please note that if you upload PHPUnit to a webserver “bad things” may happen. You have been warned.

PHPUnit is developed with a focus on development environments and the command-line. No specific testing or hardening with regard to using PHPUnit in an HTTP or web context or with untrusted input data is performed. PHPUnit might also contain functionality that intentionally exposes internal application data for debugging purposes.

If PHPUnit is used in a web application, the application developer is responsible for filtering inputs or escaping outputs as necessary and for verifying that the used functionality is safe for use within the intended context.

Vulnerabilities specific to the use outside a development context will be fixed as applicable, provided that the fix does not have an adverse effect on the primary

use case for development purposes.